The AI Vendor Due-Diligence Questionnaire

AVRF Instrument for Third-Party AI Systems, Models and APIs

Nabeel Khan
iSystematic Inc.
ORCID 0009-0005-5364-914X

Questionnaire Specification, Version 1.0
30 August 2026
doi.org/10.5281/zenodo.22170146
CC BY 4.0

Contents

This instrument is meant to be taken and used . . . 3

Abstract **3**

Notation **4**
Defined terms . . . 4

1. Introduction **4**
1.1 The problem . . . 4
1.2 Why a published questionnaire is the answer . . . 5
1.3 Contribution . . . 5
1.4 Scope . . . 5
1.5 Non-goals . . . 5

2. How the Instrument Is Used (Normative) **6**
2.1 Position in the lifecycle . . . 6
2.2 Applicability by classification . . . 6
2.3 Questions are not optional . . . 6
2.4 What to run alongside . . . 7
2.5 Re-issue . . . 7

3. Answers, Evidence and Assertions (Normative) **7**
3.1 Every question has a fixed answer format . . . 7
3.2 Every question has an evidence expectation . . . 7
3.3 The assertion rule . . . 7
3.4 Non-answers are recorded, not chased away . . . 8
3.5 Making an answer contractual . . . 8
3.6 Figure 2: why the format makes answers comparable . . . 8

4. The Questionnaire (Normative) **8**
4.1 Section A. Provenance and identity . . . 8
4.2 Section B. Training data . . . 10
4.3 Section C. Evaluation and performance . . . 10
4.4 Section D. Incident history . . . 11
4.5 Section E. Subprocessors and supply chain . . . 11
4.6 Section F. Model change and notification . . . 12
4.7 Section G. Exit and portability . . . 12

4.8 Question count 13

5. Recording a Response (Normative) 13

6. The Machine-Readable Layer (Normative) 13
6.1 The files 13
6.2 They are generated, not authored 14
6.3 Requirements on tooling built on this instrument 14

7. Version Policy (Normative) 14
7.1 Identifiers are permanent 14
7.2 Adding a question is a minor version 14
7.3 Deprecating a question keeps it visible 14
7.4 Changing the meaning of a question is a major version 14
7.5 Answer options 14

8. Reuse Grant (Normative) 14

9. Limitations and What Has Not Been Tested 15
9.1 Comparability is conferred by use, not by design 15
9.2 It elicits answers, it does not verify them 15
9.3 The questions age at different rates 15
9.4 The classification thresholds are asserted 15
9.5 Length is a real cost 15
9.6 What would falsify the instrument 15
9.7 Research questions 16

10. References 16

Appendix A. Scoring (Informative) 17
A.1 A three-value scale per question 17
A.2 Two ratios rather than one score 17
A.3 Questions an institution may wish to weight 17
A.4 What a score cannot do 17

Appendix B. Publication Provenance 17

Document History 18

About the Author 18

Licence 18

How to attribute this work 18

Questionnaire Specification, Version 1.0

Author: Nabeel Khan
ORCID: 0009-0005-5364-914X
Affiliation: iSystematic Inc.
Version: 1.0
Date: 30 August 2026
Status: Public technical specification and instrument. Self-declared use. Not a certification scheme.
Licence: Creative Commons Attribution 4.0 International (CC BY 4.0)
DOI (cite this): https://doi.org/10.5281/zenodo.22170146
This version: https://doi.org/10.5281/zenodo.22170147

Cite as: Khan, N. A. (2026). *The AI Vendor Due-Diligence Questionnaire: AVRF Instrument for Third-Party AI Systems, Models and APIs. Questionnaire Specification, Version 1.0.* Zenodo. https://doi.org/10.5281/zenodo.22170146

This instrument is meant to be taken and used

Any institution may issue this questionnaire. Any vendor may answer it. Anyone may reproduce it, embed it in a procurement process, translate it, extend it, or build tooling on it, under CC BY 4.0, with attribution and without asking permission. Section 8 states the grant in full.

That is the point of publishing it rather than a courtesy attached to it. A due-diligence questionnaire is useful in proportion to how many institutions ask the same questions, because a vendor that has answered once can answer again, and an institution can compare two vendors only if both were asked the same thing in the same form.

Trademark notice. The AI Vendor Risk Framework (AVRF)™ and the MESA Framework™ are trademarks of the author and iSystematic Inc. Text, questionnaire, data files and spreadsheet are licensed CC BY 4.0; the licence grants no rights in the marks. **Completing, reproducing or embedding this questionnaire requires no trademark permission and confers no endorsement.**

Abstract

Most of an institution's exposure to artificial intelligence arrives through a vendor boundary it cannot inspect. The model is not visible, the training data is not disclosed, the evaluation was performed by the party selling the result, and the institution's own governance machinery, however well built, stops at the contract.

The instruments that exist do not close that gap. General third-party security questionnaires establish that a supplier manages information security competently, which is necessary and says nothing about what a model was trained on, how it was evaluated, whether it has failed before, or what happens when it is silently replaced. Instruments aimed at AI have begun to appear. FS-ISAC published a Generative AI Vendor Evaluation and Qualitative Risk Assessment guide and questionnaire in February 2024 for financial services [9]. The Cloud Security Alliance publishes the AI Controls Matrix, 243 control objectives across eighteen security domains, carrying mappings to ISO/IEC 42001:2023, NIST AI 600-1 and the EU AI Act, together with a Consensus Assessment Initiative Questionnaire for AI whose questions map to that matrix and which carries rules on ownership, evidence and documentation [10]. **The AI-CAIQ is the nearest prior art, and this instrument does not duplicate it.** Two differences fix what each is for, and neither is a criticism of the other. The AI-CAIQ is a self-assessment: the vendor completes it and may submit it to the CSA STAR Registry, whereas this instrument is issued by an institution to a vendor as an act of diligence, and the issuing party is what determines which questions are asked and what evidence is required with them. And the matrix is shaped by control and compliance across security domains, whereas this instrument is shaped by the questions a model raises: provenance, training data, evaluation, incident history, subprocessors, silent model change and exit. What is still missing is an instrument of that second shape which fixes an answer format and a stated evidence expectation for every question, records the difference between an answer and an assertion, covers models beyond the generative case, and is licensed for reuse. Absent one, most institutions write their own, no two are comparable, and vendors answer the same underlying question in twenty incompatible forms.

This specification publishes one. It defines a questionnaire of fifty-six questions in seven sections: provenance and identity, training data, evaluation and performance, incident history, subprocessors and supply chain, model change and notification, and exit and portability. **Every question carries a fixed answer format and a stated evidence expectation**, which is what makes two completed questionnaires comparable rather than merely similar. A question answered without its evidence is recorded as a vendor assertion, and the instrument makes that distinction structural rather than leaving it to the reader.

The questionnaire ships in four forms from one source: this specification, a machine-readable form definition, a JSON Schema for validating a completed response, and a fillable spreadsheet. They are generated from the tables in Section 4, so they cannot disagree with it.

A scoring appendix is provided and is explicitly informative. Scoring a due-diligence response is a judgement an institution makes against its own risk appetite, and a scheme that presented itself as normative would be asserting an appetite on the institution's behalf.

The specification states what it does not do. It does not assess the vendor's security posture, its financial standing, or the permissibility of its products. It does not establish that answers are true. **Version 1.0 is a design published**

doi.org/10.5281/zenodo.22170146

for institutions to issue, and no institution unconnected to the author has yet been observed using it, no supervisor has reviewed it, and Section 9 states what would falsify it.

It is a specification and an instrument, not a certification scheme, and no conformity assessment body operates against it.

Keywords: AI governance; vendor risk; third-party risk management; due diligence; model provenance; procurement; supply chain; model risk management; regulated industries.

Notation

This specification uses **MUST**, **MUST NOT**, **SHOULD**, **SHOULD NOT** and **MAY** as the normative verbal forms.

- **MUST** indicates a requirement. A response or a use of the instrument that does not meet it is not conformant with this specification.
- **SHOULD** indicates a recommendation. Departure requires a recorded rationale.
- **MAY** indicates a permission.

These forms bind the use of the instrument. They do not bind any vendor, who is under no obligation arising from this document to answer anything. What binds a vendor is the institution's contract, and Section 3.5 states how an institution makes an answer contractual if it wishes to.

Defined terms

Vendor. The party supplying an AI capability, whether as a model, a hosted API, an embedded feature of a larger product, or a service performed using a model.

AI capability. Any function whose behaviour is materially determined by a model. **A feature described in marketing as AI-powered is in scope whether or not the vendor calls it a model.**

Response. A completed questionnaire, identified by the questionnaire version, the vendor, the capability, and a date.

Evidence. An artifact attached to an answer that a third party could examine: a document, a report, a record, a URL to a stable page. **A statement by the vendor is not evidence of itself.**

Assertion. An answer supplied without its stated evidence. Assertions are permitted and MUST be recorded as assertions, per 3.3.

Sections 2 through 8 are normative. Sections 1 and 9, and Appendix A, are informative, except where they state a requirement using **MUST**.

---

1. Introduction

1.1 The problem

An institution governing its own models can inspect them. It knows what data went in, what evaluation was run, who approved the result and what happens when the model changes, because it did all four itself.

None of that is true across a vendor boundary, and the proportion of institutional AI that sits behind one is large and rising. The institution's position is that it must form a view about a system it cannot see, from information the seller chooses to provide, on a timescale set by a procurement process.

The natural response is to ask. What institutions actually ask is the problem. Three patterns recur.

The security questionnaire, extended. An existing third-party questionnaire is issued with a few AI questions appended. It establishes that the vendor manages information security, which is worth knowing and answers none of the model-specific questions.

doi.org/10.5281/zenodo.22170146

The bespoke list. Someone writes twenty questions specific to the deal. The questions are often good. They are used once, they are not comparable with anything, and the next deal starts again.

The vendor's own material. The institution reads what the vendor published. This is not diligence. It is reading marketing carefully.

The position is no longer only a matter of prudence. Supervisory guidance on model risk now expressly reaches models and data obtained from third parties, in Canada under OSFI Guideline E-23 [6] and in the United States under SR 26-2 [7]. **Neither instrument tells an institution what to ask a vendor**, which is the gap this questionnaire occupies rather than one it claims to close on either regulator's behalf.

1.2 Why a published questionnaire is the answer

A due-diligence instrument gets its power from being **shared**, and for two reasons that compound.

Comparability. An institution can rank two vendors only if both answered the same question in the same form. Two bespoke questionnaires produce two narratives, and a narrative comparison is an impression.

Answering cost. A vendor asked the same question by many institutions answers it once, well, with evidence attached. A vendor asked twenty variants answers each cheaply. **The quality of the answers an institution receives depends on how many other institutions asked the same thing**, which is a property no institution can create alone.

That is why this instrument is published under a licence that permits anyone to take it, and why Section 8 states the grant in unusually plain terms.

1.3 Contribution

1. **Fifty-six questions in seven sections**, each with a fixed answer format and a stated evidence expectation. Section 4.
2. **A structural distinction between an answer and an assertion**, so that an unevidenced answer is recorded as one rather than read as one. Section 3.3.
3. **Four representations generated from one source**, so the document, the form definition, the response schema and the spreadsheet cannot disagree. Section 6.
4. **An informative scoring appendix**, marked informative because the judgement belongs to the institution. Appendix A.

1.4 Scope

Due diligence on third-party AI systems, models and APIs, at onboarding and on renewal, by an institution acquiring them. The instrument is calibrated to regulated institutions and is usable by any institution.

Within the governance family it is the diligence instrument of the AI Vendor Risk Framework, which instantiates the Operational Machinery altitude of the MESA Framework [1]. That placement matters only in that it fixes what the instrument is responsible for and what it is not, and Section 2.4 states what an institution should run alongside it.

1.5 Non-goals

- **Not a security questionnaire.** Information security, resilience and privacy programme questions are covered competently by existing shared instruments and are deliberately not duplicated. 2.4 states what an institution should run alongside this.
- **Not a financial or commercial assessment.**
- **Not a verification.** The questionnaire elicits answers and evidence. **It does not establish that the answers are true**, and 9.2 states what that limits.
- **Not a scoring standard.** Appendix A is informative.
- **Not a certification scheme.** No conformity assessment body operates against it, and completing it confers no status.
- **Not a substitute for a contract.** An answer becomes binding only if the institution makes it so, per 3.5.

doi.org/10.5281/zenodo.22170146

2. How the Instrument Is Used (Normative)

2.1 Position in the lifecycle

The questionnaire is the diligence stage of the AI Vendor Risk Framework [3]. Its outputs are consumed as entry criteria at the first and fourth gates of the Five-Gate Deployment Model [4], and it is re-issued at the triggers stated at 2.5.

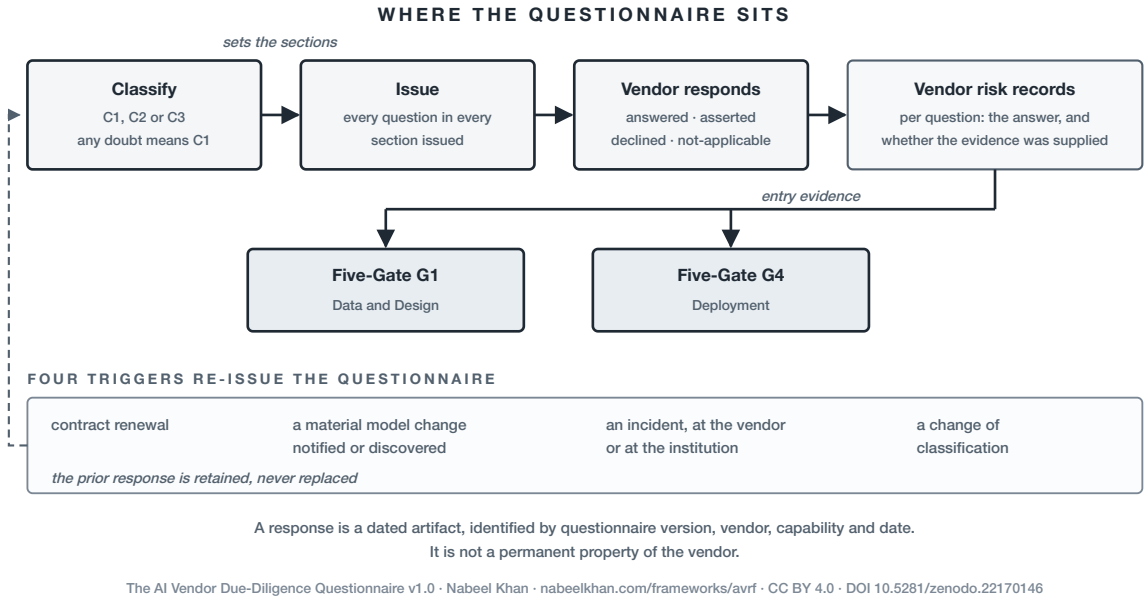


Figure 1. Where the questionnaire sits. Vendor classification determines the applicable sections; the completed response and its evidence become vendor risk records; those records are entry evidence at the data and design gate and again at the deployment gate; and the response is re-issued at renewal, at a material model change, and after an incident. A response is a dated artifact rather than a permanent property of the vendor.

2.2 Applicability by classification

An institution MUST classify the capability before issuing the questionnaire, and MUST record the classification with the response, because the classification determines which sections are required and a reader cannot interpret a partial response without it.

Class	Description	Required sections
C1	The capability influences a decision about a person, or processes personal or otherwise restricted data	All seven
C2	The capability is used in production and neither condition of C1 holds	A, B, C, D, F, G
C3	The capability is evaluative, internal, and not in a production decision path	A, C, D, F

A capability MUST be classified C1 where any doubt exists. Under-classification is the failure mode that matters: an over-classified capability costs the vendor answering effort, and an under-classified one produces a response missing the sections that would have mattered.

2.3 Questions are not optional

An institution issuing a section MUST issue every question in it. Removing questions is what destroys comparability, and an institution that removes questions has produced a bespoke questionnaire that resembles this one.

An institution MAY **add** questions, and SHOULD mark added questions with an identifier outside the `A` to `G` prefixes so that a reader can tell the instrument from the addition.

doi.org/10.5281/zenodo.22170146

2.4 What to run alongside

This questionnaire deliberately omits information security, resilience, privacy programme and financial questions. An institution SHOULD issue an established shared security questionnaire alongside it and SHOULD NOT expect either instrument to cover the other's ground. An institution operating a management system under ISO/IEC 42001 [8] will find that this questionnaire supplies evidence into it and does not duplicate it. **Two instruments that each do one job well are better than one that does both badly**, and duplicating the security questions here would have made the instrument longer and no more useful.

2.5 Re-issue

A response is a dated artifact and not a permanent property of the vendor. The questionnaire MUST be re-issued on each of the following, and the institution MUST retain the prior response rather than replacing it.

1. Contract renewal.
2. A material model change notified under section F, or discovered.
3. An incident involving the capability, whether at the vendor or at the institution.
4. A change of classification under 2.2.

---

3. Answers, Evidence and Assertions (Normative)

3.1 Every question has a fixed answer format

Each question in Section 4 carries an answer format, and **a response MUST use it.** The formats are:

Format	Meaning
`single-select`	Exactly one of the stated options
`multi-select`	Zero or more of the stated options
`yes-no-evidence`	Yes or No, with the stated evidence required when Yes
`date`	An ISO 8601 date
`number`	A number, with the unit stated in the question
`free-text`	Prose, which SHOULD be under 200 words
`document`	A reference to an attached or linked document

The formats exist so that responses can be compared and processed. **A free-text answer supplied where a `single-select` was asked is a non-response to that question** and MUST be recorded as such.

3.2 Every question has an evidence expectation

Each question states what evidence would substantiate the answer. **An institution MUST record, per question, whether the stated evidence was supplied.**

3.3 The assertion rule

An answer supplied without its stated evidence MUST be recorded as an assertion, and MUST NOT be recorded as a finding.

This is the instrument's central discipline and it is one line of bookkeeping. A vendor stating that its training data excludes a category is telling the institution what it believes or wishes to convey. A vendor stating it and attaching the data provenance record is giving the institution something a third party could examine. Both are useful and they are not the same, and an institution that files them identically has lost the distinction at exactly the point where it matters.

Assertions are permitted. A vendor may have good reasons to withhold evidence, including confidentiality obligations to others. The requirement is not that everything is evidenced; it is that the institution knows which answers are.

doi.org/10.5281/zenodo.22170146

3.4 Non-answers are recorded, not chased away

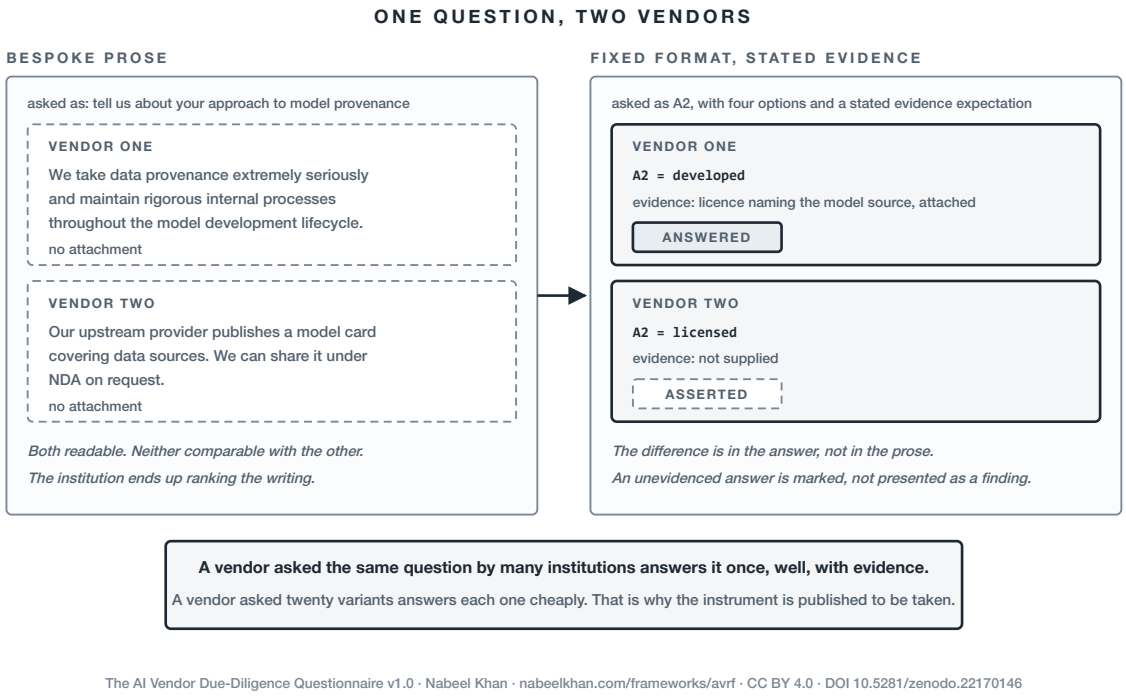
Four outcomes are permitted for any question and **a response MUST use one of them**: an answer, an answer marked as an assertion, `declined` with a stated reason, or `not-applicable` with a stated reason.

`declined` MUST NOT be silently converted into a blank. A pattern of declines is itself a finding, and it is invisible if declines are erased.

3.5 Making an answer contractual

Nothing in this specification binds a vendor. An institution that wishes an answer to bind SHOULD incorporate the response by reference into the contract, and SHOULD require notification when any incorporated answer ceases to be accurate. **Section F is written to make that practical**, since a model-change notification obligation is worth more than most of the answers it protects.

3.6 Figure 2: why the format makes answers comparable



The AI Vendor Due-Diligence Questionnaire v1.0 · Nabeel Khan · nabeelkhan.com/frameworks/avrf · CC BY 4.0 · DOI 10.5281/zenodo.22170146

Figure 2. Two vendors, one question. On the left, the same question asked in two bespoke forms produces two narratives that can be read but not compared, and the institution ends up ranking prose. On the right, a fixed answer format and a stated evidence expectation produce two responses in the same shape, in which the difference between the vendors is visible in the answer rather than in the writing, and in which an unevidenced answer is marked as an assertion rather than presented as a finding.

---

4. The Questionnaire (Normative)

Fifty-six questions in seven sections. Question identifiers are normative and MUST NOT be renumbered or reused; the version policy at Section 7 states how questions are added and deprecated.

4.1 Section A. Provenance and identity

Establishes what the capability actually is. This is the section a diligence exercise can fail without noticing it has failed: the institution assesses a product, and the product is a thin layer over a model the vendor does not control.

doi.org/10.5281/zenodo.22170146



Figure 3. The seven sections and what each is for. Provenance establishes what the thing is; training data and evaluation establish how it came to behave as it does; incident history establishes what has already gone wrong; subprocessors establish who else is involved; model change establishes whether the institution will know when the thing it assessed is replaced; and exit establishes whether the institution can leave. The sections are ordered so that a vendor unable to answer the early ones rarely needs to be asked the later ones.

ID	Question	Answer format	Evidence expected
A1	What is the name and version identifier of the AI capability being supplied?	`free-text`	Product documentation naming the version
A2	Is the underlying model developed by you, licensed from a third party, or an open-weights model you host?	`single-select`: developed / licensed / open-weights / mixed / not-disclosed	Documentation or licence naming the model source
A3	If licensed or open-weights, name the model and the provider.	`free-text`	The licence or provider agreement
A4	Where is inference performed, by jurisdiction?	`multi-select`: named jurisdictions	Architecture or hosting documentation
A5	Can the capability be operated without any data leaving a named jurisdiction?	`yes-no-evidence`	A deployment option description or configuration
A6	Do you retain customer inputs or outputs, and for how long?	`free-text`	The data retention policy applying to this capability
A7	Are customer inputs or outputs used to train, fine-tune or evaluate any model?	`single-select`: never / only-with-opt-in / by-default-with-opt-out / yes / not-disclosed	The contractual term or policy stating it
A8	Is there a documented option to disable the behaviour in A7 entirely?	`yes-no-evidence`	The configuration or contract term

doi.org/10.5281/zenodo.22170146

4.2 Section B. Training data

Establishes how the model came to behave as it does. **The most useful answer in this section is frequently a candid statement of what the vendor does not know**, particularly where the model is licensed.

ID	Question	Answer format	Evidence expected
B1	What categories of data was the model trained on?	`free-text`	A model card, data statement or equivalent
B2	Do you hold a documented provenance record for the training data?	`yes-no-evidence`	The provenance record, or a description of its structure
B3	If the model is licensed or open-weights, what do you know about its training data, and how did you come to know it?	`free-text`	The provider's published material, cited
B4	Does the training data include personal data?	`single-select`: no / yes / unknown / not-disclosed	The data protection assessment or provider statement
B5	What lawful basis or permission covers the use of any personal data in training?	`free-text`	The assessment or legal analysis relied on
B6	Were any categories of data deliberately excluded, and which?	`free-text`	The exclusion policy or filtering description
B7	Has the training data been assessed for the presence of copyrighted material used without permission?	`single-select`: assessed-no-issues / assessed-issues-identified / not-assessed / not-disclosed	The assessment
B8	Can a customer request that specific data be excluded from future training?	`yes-no-evidence`	The process description
B9	What is the cut-off date of the training data?	`date`	Documentation stating it

4.3 Section C. Evaluation and performance

Establishes what was measured, by whom, and on what. **C6 is the question with the most capacity to change an institution's view**, because a benchmark result the vendor cannot reproduce for a customer is a marketing figure.

ID	Question	Answer format	Evidence expected
C1	What evaluations have been performed on the capability?	`free-text`	Evaluation reports
C2	Were any evaluations performed by a party independent of you?	`yes-no-evidence`	The independent report, naming the party
C3	On what data were the evaluations performed, and is it disclosed?	`single-select`: public-benchmark / proprietary-disclosed / proprietary-undisclosed / not-evaluated / not-disclosed	The evaluation methodology
C4	What is the measured error or failure rate, and on which task?	`free-text`	The evaluation result with its methodology
C5	Has the capability been evaluated for differential performance across groups of people?	`yes-no-evidence`	The fairness or subgroup evaluation

doi.org/10.5281/zenodo.22170146

ID	Question	Answer format	Evidence expected
C6	Can a customer reproduce any published performance claim on their own data?	`yes-no-evidence`	The reproduction procedure or a customer evaluation kit
C7	What are the documented limits of the capability, stated as tasks it should not be used for?	`free-text`	The documentation stating limits
C8	Is a confidence, uncertainty or abstention signal exposed to the customer?	`yes-no-evidence`	The API or product documentation
C9	Has the capability been evaluated for prompt injection, jailbreak or equivalent adversarial input?	`yes-no-evidence`	The adversarial evaluation report

4.4 Section D. Incident history

Establishes what has already gone wrong. **A vendor reporting no incidents is either very new, very lucky, or not counting**, and D4 exists to tell the three apart.

ID	Question	Answer format	Evidence expected
D1	Have there been incidents in which the capability produced materially wrong or harmful output?	`yes-no-evidence`	Incident summaries
D2	Have there been incidents involving unavailability of the capability in the past 24 months?	`yes-no-evidence`	Availability records or status history
D3	Have there been security incidents affecting customer data handled by the capability?	`yes-no-evidence`	Incident summaries or breach notifications
D4	How do you define an incident for this capability, and where is that definition recorded?	`free-text`	The incident definition or policy
D5	Do you maintain a public incident history or status page?	`yes-no-evidence`	The URL
D6	Within what period are customers notified of an incident affecting them?	`free-text`	The contractual or policy commitment
D7	Has any regulator, supervisor or authority raised a matter concerning this capability?	`single-select`: no / yes / not-disclosed	A description of the matter and its status
D8	Is a post-incident review performed and made available to affected customers?	`yes-no-evidence`	An example review, redacted as necessary

4.5 Section E. Subprocessors and supply chain

Establishes who else is involved. Applies to class C1.

ID	Question	Answer format	Evidence expected
E1	List every subprocessor that may access customer data through this capability.	`free-text`	The subprocessor list
E2	Is the subprocessor list published and versioned?	`yes-no-evidence`	The URL and its change history
E3	How much notice is given before a subprocessor is added?	`free-text`	The contractual commitment

doi.org/10.5281/zenodo.22170146

ID	Question	Answer format	Evidence expected
E4	May a customer object to a new subprocessor, and what follows if they do?	`free-text`	The objection process
E5	Does any subprocessor use customer data for its own purposes, including training?	`single-select`: no / yes / not-disclosed	The subprocessor terms
E6	If the underlying model is a third party's, what are your contractual rights against that provider on model change and on incident?	`free-text`	The relevant terms, redacted as necessary
E7	Would a failure of any single subprocessor make the capability unavailable?	`yes-no-evidence`	The dependency or resilience analysis

4.6 Section F. Model change and notification

Establishes whether the institution will know when the thing it assessed has been replaced. **This is the section with the highest ratio of value to length**, because every other answer in the questionnaire describes a model that can be changed under the institution without notice.

ID	Question	Answer format	Evidence expected
F1	Can the underlying model be changed without a change to the API or interface?	`single-select`: no / yes / not-disclosed	The versioning documentation
F2	What notice is given before a model change that could alter output behaviour?	`free-text`	The contractual or policy commitment
F3	How do you define a material model change?	`free-text`	The definition, as recorded
F4	Can a customer pin a specific model version, and for how long?	`yes-no-evidence`	The pinning documentation and its support window
F5	Are changes to system prompts, guardrails or safety filters notified?	`single-select`: always / material-only / never / not-disclosed	The notification policy
F6	Is a changelog for the capability published and versioned?	`yes-no-evidence`	The URL
F7	Can a customer evaluate a new version before it is applied to them?	`yes-no-evidence`	The preview or staging process
F8	Is a rollback to the prior version available to a customer after a change?	`yes-no-evidence`	The rollback process and its window

4.7 Section G. Exit and portability

Establishes whether the institution can leave. **A tested exit is a capability and an untested one is a plan**, and G7 is the question that distinguishes them.

ID	Question	Answer format	Evidence expected
G1	On termination, in what form is customer data returned?	`free-text`	The export format specification
G2	Within what period is data returned after a termination request?	`free-text`	The contractual commitment
G3	Within what period is customer data deleted from your systems and those of subprocessors?	`free-text`	The deletion commitment and its scope

doi.org/10.5281/zenodo.22170146

ID	Question	Answer format	Evidence expected
G4	Is deletion confirmed in writing, and does the confirmation cover subprocessors and backups?	`yes-no-evidence`	An example confirmation
G5	Are prompts, configurations, fine-tunes or other customer-created artifacts exportable?	`single-select`: all / some / none / not-disclosed	The export documentation
G6	What would prevent a customer from moving this workload to another provider?	`free-text`	An honest description, which is the point of the question
G7	Has a customer exit been performed and completed at least once?	`yes-no-evidence`	A reference, redacted as necessary

4.8 Question count

Eight in A, nine in B, nine in C, eight in D, seven in E, eight in F, seven in G. **Fifty-six questions.** The count is stated so that a truncated copy of the instrument is detectable.

---

5. Recording a Response (Normative)

A response MUST carry all of the following, and a response missing any of them cannot be interpreted later by someone who was not present.

1. The **questionnaire version** answered against.
2. The **vendor** and the **capability**, identified as in A1.
3. The **classification** under 2.2 and which sections were issued.
4. The **date** the response was received.
5. Per question: the **answer**, whether the stated **evidence was supplied**, and where the evidence is held.
6. The **name of the person** at the institution who received and reviewed the response.

Where an institution also operates the engineering family's evidence conventions, a response SHOULD be recorded so that it states the boundary it establishes, the freedom it permits and the evidence supporting both, in the shape of a BOE Declaration [2], so that a vendor record joins the institution's other evidence rather than sitting apart from it.

Item 5 is the item easiest to omit, because it is the only one whose cost scales with the number of questions rather than being recorded once, and it is the reason the assertion rule at 3.3 exists. A response recorded without per-question evidence status is a document; a response recorded with it is a finding an institution can act on and defend.

---

6. The Machine-Readable Layer (Normative)

6.1 The files

File	What it is
`avrf-questionnaire-v1.0.json`	The form definition. Every question, its section, its answer format, its options and its evidence expectation
`avrf-response-schema-v1.0.json`	The JSON Schema a completed response validates against
`avrf-questionnaire-v1.0.xlsx`	The fillable spreadsheet, one sheet per section plus a response header

doi.org/10.5281/zenodo.22170146

6.2 They are generated, not authored

All three are generated from the tables in Section 4 by the build chain of this deposit. They therefore cannot disagree with the specification, and a question edited in Section 4 propagates to all three or the build fails.

Section 4 governs. Where a file and Section 4 disagree, Section 4 is correct and the file is defective.

6.3 Requirements on tooling built on this instrument

Tooling that issues the questionnaire or processes responses:

1. **MUST record the questionnaire version** in every response it produces, per Section 5.
2. **MUST preserve the distinction between an answer, an assertion, a decline and a not-applicable**, per 3.3 and 3.4. Collapsing any of the four into a blank destroys the property the instrument exists to create.
3. **MUST NOT present a computed score as a finding of this specification.** Appendix A is informative and a score is the institution's judgement.
4. **SHOULD carry deprecated questions forward** in the form stated at 7.3, so that historical responses remain interpretable.

---

7. Version Policy (Normative)

A questionnaire that changes carelessly makes its own history unreadable. Three rules keep completed responses interpretable.

7.1 Identifiers are permanent

A question identifier MUST NOT be renumbered or reused. `C6` means one thing for the life of the instrument.

7.2 Adding a question is a minor version

A new question is appended within its section and takes the next free number. **A response to an earlier version remains valid** and is read as not having been asked the new question, which is different from having declined it.

7.3 Deprecating a question keeps it visible

A question is never deleted. It is marked **deprecated** with the version in which it was deprecated and the reason. Tooling SHOULD carry deprecated questions forward marked as such, so that a response from an earlier version can still be read against the current instrument.

7.4 Changing the meaning of a question is a major version

If a question's wording changes in a way that could change the answer, it is a new question with a new identifier and the old one is deprecated. Editing a question in place and keeping its number silently invalidates every historical response, which is the failure this policy exists to prevent.

7.5 Answer options

Adding an option to a `single-select` is a minor version. Removing one is major, because a historical response may have used it.

---

8. Reuse Grant (Normative)

This instrument is published to be adopted. The licence is CC BY 4.0 and the grant is stated here in plain terms so that nobody has to reason about it before acting.

Any institution MAY issue this questionnaire to any vendor, embed it in a procurement system, translate it, add questions to it per 2.3, and build commercial tooling on it.

doi.org/10.5281/zenodo.22170146

Any vendor MAY complete it, publish a completed response, reuse a response across customers, and state that it has answered the AVRF questionnaire.

Anyone MAY reproduce the questionnaire, the form definition, the schema and the spreadsheet, in whole or in part, including in commercial products.

The only condition is attribution, satisfied by citing this specification with its DOI and version.

No permission is required, and none will be given, in the sense that there is nothing to grant that the licence does not already grant. An institution or vendor that writes to ask should take that as a yes.

Three limits, which are limits on representation rather than on use.

1. **Completing the questionnaire is not a certification** and MUST NOT be represented as one. There is nothing to be certified against and no body to do it.
2. **The trademarks are not licensed.** The text is CC BY; AVRF and MESA are not, and neither is needed to use the instrument.
3. **A modified questionnaire MUST NOT be presented as this one.** Added questions are marked per 2.3; a version with questions removed is a derivative and should be described as one, because the value of the instrument is that a response to it is comparable with another response to it.

---

9. Limitations and What Has Not Been Tested

9.1 Comparability is conferred by use, not by design

This is version 1.0 of the questionnaire for a framework specified at chapter 14 of [5], and comparability is the one property a design cannot carry on its own. No institution unconnected to the author has been observed issuing it, no vendor has answered it, and no supervisor has reviewed it. Comparability across vendors is conferred by parties other than the author asking the same questions in the same form, which is what publication is for.

9.2 It elicits answers, it does not verify them

The questionnaire produces what a vendor is willing to state and what a vendor is willing to evidence. **It establishes neither that a statement is true nor that an evidence document is what it appears to be.** The assertion rule at 3.3 records which answers are unevidenced, which is a smaller claim than verification and the largest claim an instrument of this kind can support.

9.3 The questions age at different rates

Sections A, E, F and G ask about arrangements and will age slowly. Sections B and C ask about practices in a field that is changing quickly, and some of those questions will read as dated within a few years. **The version policy at Section 7 is written for that**, and 7.3's rule that a question is deprecated rather than deleted exists because a dated question with historical answers is more useful than a gap.

9.4 The classification thresholds are asserted

The three classes at 2.2 and the sections assigned to each are the author's judgement, calibrated to regulated institutions. **No evidence supports the specific boundaries**, and an institution may reasonably set them differently.

9.5 Length is a real cost

Fifty-six questions, with evidence, is a significant ask of a vendor, particularly a small one. An institution issuing it to every supplier of every AI feature will meet resistance and will deserve to. **2.2 exists to make the ask proportionate**, and an institution that issues all seven sections to every vendor has misused the instrument rather than applied it thoroughly.

9.6 What would falsify the instrument

The instrument is falsified if institutions issuing it are found to reach the same vendor decisions, with the same rate of subsequent surprise, as institutions issuing a general third-party security questionnaire with a few AI questions appended.

doi.org/10.5281/zenodo.22170146

Its whole claim is that model-specific questions with fixed formats and evidence expectations change the decision. If they do not, the additional length is a cost with no return.

Two narrower findings would refute parts of it. If responses recorded with per-question evidence status produce no different action from responses recorded without it, the assertion rule at 3.3 is bookkeeping. And if two institutions issuing the same instrument to the same vendor receive materially different responses, the comparability claim fails at its foundation.

9.7 Research questions

1. Do institutions using this instrument experience fewer vendor-originated AI incidents than institutions using a general third-party questionnaire?
2. Does a vendor asked the same question by many institutions supply better evidence than one asked a bespoke variant?
3. Which of the fifty-six questions actually change a decision, and could the instrument be materially shorter?
4. Are responses from the same vendor to different institutions consistent?

Question three is the one that would most improve the instrument, and it can only be answered from a corpus of real responses. Anyone holding one is invited to make contact through the ORCID record in the front matter.

---

10. References

Every reference was verified against a live primary source on 29 August 2026, except reference [10], verified on 30 August 2026. Each was verified with a deliberate failing control, because a check that cannot fail proves nothing.

[1] Khan, N. A. (2026). *The MESA Framework: A Four-Altitude Diagnostic Model for Institutional AI Governance. Framework Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22109836

[2] Khan, N. A. (2026). *A Pattern Language for Production LLM Platforms: Governed Routing, Agent Orchestration, and AI-Native Delivery. Pattern Language Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22109864

[3] Khan, N. A. (2026). *The Defensible AI Framework Registry: Canonical Names, Definitions and Relationships for the Governed Production AI Discipline. Registry Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170112

[4] Khan, N. A. (2026). *The Five-Gate Deployment Model: A Deployment Discipline for AI Systems. Deployment Model Specification.* Zenodo. Concept DOI https://doi.org/10.5281/zenodo.22170122

[5] Khan, N. A. (2026). *AI Governance and Compliance Frameworks for the Middle East: The Enterprise Playbook.* First Edition. iSystematic Inc. ISBN 978-1-0678960-1-0

[6] Office of the Superintendent of Financial Institutions, Canada (2025). *Guideline E-23, Model Risk Management (2027).* Published 11 September 2025, effective 1 May 2027. Scope includes models and data sourced from third parties.

[7] Board of Governors of the Federal Reserve System, Office of the Comptroller of the Currency and Federal Deposit Insurance Corporation (2026). *SR 26-2, Revised Guidance on Model Risk Management.* Issued 17 April 2026. Supersedes and replaces SR 11-7 (2011) and SR 21-8 (2021).

[8] International Organization for Standardization and International Electrotechnical Commission (2023). *ISO/IEC 42001:2023, Information technology. Artificial intelligence. Management system.* First edition, December 2023.

[9] Financial Services Information Sharing and Analysis Center (2024). *Generative AI Vendor Evaluation and Qualitative Risk Assessment.* Guide and questionnaire tool, February 2024. Sector-specific to financial services and scoped to generative AI.

[10] Cloud Security Alliance. *AI Controls Matrix (AICM) and the Consensus Assessment Initiative Questionnaire for AI (AI-CAIQ).* 243 control objectives across eighteen security domains, with mappings to ISO/IEC 42001:2023, NIST AI 600-1 and the EU AI Act. The AI-CAIQ is a set of questions that map to the matrix, completed by the

doi.org/10.5281/zenodo.22170146

vendor as a self-assessment and submittable to the CSA STAR Registry, with guidance on ownership, evidence and documentation. https://cloudsecurityalliance.org/artifacts/ai-controls-matrix, retrieved 30 August 2026. No question count is stated for the AI-CAIQ because none was verified from the source, and no publication year is stated because none appears on it.

Appendix A. Scoring (Informative)

This appendix is informative and is not part of the specification's requirements. It is provided because institutions will score responses, and a stated method they can adapt is better than each inventing one.

It is informative for a reason rather than by convention. A score expresses a risk appetite. A scoring scheme published as normative would assert an appetite on behalf of every institution using it, and two institutions with different appetites should reach different conclusions from the same response. **An institution MUST NOT represent a score computed under this appendix as a finding of this specification**, and 6.3.3 places the same requirement on tooling.

A.1 A three-value scale per question

Value	Meaning
Satisfied	Answered in the required format, with the stated evidence supplied
Asserted	Answered in the required format, evidence not supplied
Open	Declined, not answered, or answered in the wrong format

`not-applicable` is excluded from the denominator rather than counted as satisfied.

A.2 Two ratios rather than one score

A single number hides the distinction the instrument exists to create. An institution SHOULD compute two:

- **Evidence ratio**: satisfied divided by applicable questions.
- **Response ratio**: satisfied plus asserted, divided by applicable questions.

A vendor with a high response ratio and a low evidence ratio has answered everything and evidenced little, which is a different vendor from one that answered less and evidenced what it answered.

A.3 Questions an institution may wish to weight

Some questions carry more consequence than their share of the count. An institution may wish to weight **A7** and **A8** on training use of customer data, **F1**, **F2** and **F4** on silent model change, **C6** on reproducibility, and **G7** on tested exit. **This list is an observation offered for consideration, not a requirement**, and an institution should derive its own weighting from its own appetite.

A.4 What a score cannot do

It cannot rank vendors across different classifications, because they were asked different sections. It cannot compare responses to different questionnaire versions without accounting for added and deprecated questions. And it cannot substitute for reading section G6, which is a free-text question whose answer is frequently the most informative thing in the response.

Appendix B. Publication Provenance

B.1 First public version of the instrument. Not peer reviewed. Deposited on Zenodo, which confers a DOI, a timestamp and citability, and confers no standard status.

doi.org/10.5281/zenodo.22170146

B.2 The framework this instrument belongs to is specified at chapter 14 of [5] and catalogued as REG-04 of [3]. **The questionnaire itself has not previously been published**, and its absence was the reason REG-04 was first drafted with the status `instrument-pending`, which this deposit closes. This deposit closes that gap.

B.3 No preprint identifier exists and no preprint relation is asserted in this record's metadata.

B.4 Publication order. This record is seventh of eight. It publishes after the Five-Gate Deployment Model [4] and before the Defensible AI Framework Registry [3], which publishes last because it cites the final identifier of every record it registers. Registry entry REG-04 remains the canonical statement of this instrument's relationships and governs where the two describe the same relationship. Both DOIs are reserved in advance and are carried by references [3] and [4].

B.5 The author operates a consulting practice performing vendor assessments, which is a conflict of interest stated here. It is a stronger conflict than in the author's other specifications, because an instrument that becomes widely used benefits its author's practice directly. **The mitigation is the reuse grant at Section 8**, which gives away everything that could otherwise be sold as access, and it is a partial mitigation rather than a complete one.

Document History

Version	Date	Summary
1.0	30 August 2026	First public version. Fifty-six questions in seven sections, the assertion rule, the version policy, the reuse grant, an informative scoring appendix, and three generated machine-readable representations

---

About the Author

Nabeel Khan is an enterprise AI architect and governance advisor, and Founder & Solutions Architect at iSystematic Inc. He has spent twenty-five years architecting enterprise data and machine-learning systems in government, healthcare, financial services and telecommunications across three continents, grounded in TOGAF, DMBOK, ISO 27001 and SOC 2.

He works on governed production AI; systems whose authority is bounded by the architecture, whose decisions carry the evidence needed to defend them, and whose behaviour the institution can explain afterwards. The frameworks specified here, and the regulatory knowledge behind them, are published as machine-accessible AI expertise and are callable over MCP without a key at mcp.nabeelkhan.com/api/mcp, so a reader may query this specification's contents directly and receive answers carrying their source.

ORCID 0009-0005-5364-914X · nabeelkhan.com · Canada

Licence

© 2026 Nabeel A. Khan. Text, questionnaire, form definition, schema and spreadsheet licensed under the Creative Commons Attribution 4.0 International licence (CC BY 4.0). The AI Vendor Risk Framework (AVRF)™ and the MESA Framework™ are trademarks of the author and iSystematic Inc.; the licence grants no rights in the marks, and no trademark permission is required to complete, reproduce or embed the questionnaire.

How to attribute this work

This work is licensed CC BY 4.0. Section 3(a)(1)(A) of that licence requires attribution in the manner the licensor requests, and Section 3(a)(1)(C) requires a link to the material where practicable. This section is that request. Please use one of the following.

Short credit, for slides, diagrams and internal documents:

doi.org/10.5281/zenodo.22170146

```
The AI Vendor Due-Diligence Questionnaire by Nabeel Khan ·
  https://nabeelkhan.com/frameworks/avrf · CC BY 4.0
```

Inline credit, for web pages, articles and product documentation:

```
Based on <a href="https://nabeelkhan.com/frameworks/avrf">The AI Vendor
  Due-Diligence Questionnaire</a> by Nabeel Khan,
licensed under <a href="https://creativecommons.org/licenses/by/4.0/">CC
  BY 4.0</a>.
```

Academic citation:

```
Khan, N. A. (2026). The AI Vendor Due-Diligence Questionnaire: AVRF
  Instrument for Third-Party AI Systems, Models and APIs.
(Version 1.0). Zenodo. https://doi.org/10.5281/zenodo.22170146
```

The DOI given is the concept DOI and always resolves to the latest version. Cite it unless you need to pin one specific version.

If you have adapted the work, say that changes were made, and do not imply that this author or iSystematic Inc. endorses your version.

Trademarks. The AI Vendor Risk Framework (AVRF)™ and the MESA Framework™ are trademarks of the author and iSystematic Inc. The CC BY licence covers this questionnaire and grants no rights in the marks. The instrument may be copied, completed and forwarded to vendors freely, with attribution.

doi.org/10.5281/zenodo.22170146